Role-based access: verification evidence

UFCEP6-0-3 second release · Camunda 8 Run 8.10.0-alpha5 · recomputed 15 October 2026 and 20 October 2026

1 What was verified

Two questions, both answered against the running cluster rather than by inspection: (a) is a user with no authorization refused the task list, and (b) does each role see only the task definitions its candidate group names in the BPMN?

Source data: 05_Test_Evidence/rbac/task-visibility.json (15 October 2026 run, the numbers quoted in the portfolio and the presentation). Recomputed on 20 October 2026 after the authorization configuration was corrected.

2 Enforcement

Both probes authenticate with HTTP basic credentials and call POST /v2/user-tasks/search.

Probe user	Authorization	Visible user tasks (15 Oct)	Visible user tasks (20 Oct)
norole.demo	no role, no group	0	0
secretary.demo	member of medical-secretaries	785	1340

The invariant is the zero: a user who is granted nothing sees nothing. The other number is not an invariant - it is the count of user tasks in the instance history, so it grows every time the acceptance cases run (785 on 15 October, 1340 on 20 October). Quoting it without a date invites the reader to think it is a property of the model.

Configuration required for this to hold: camunda.security.authentication.unprotected-api: false together with camunda.security.authorizations.enabled: true. With unprotected-api: true the REST API answers without evaluating authorization and both probes see the same list - which is exactly what a run on 20 October showed before the setting was corrected.

3 Routing: which role sees which task definitions

Candidate group (role)	Task definitions routed	Definitions
administrative-management	0	
call-handling-team	6	T_AnswerAdministrative, T_ClassifyEnquiry, T_Enquiry, T_RecordContactAttempt, T_RecordEnquiryOutcome, T_TelephonePatient
clinical-nurse-specialist-team	2	T_FollowUp, T_ProvideCnsContactDetails
consultant-team	19	T_ApproveClinicLetter, T_Authorise, T_ClinicalReview, T_ClinicalReviewReferral, T_Complete,

		T_CompletePathway, T_Consultation, T_CreateAuthorisedRequest, T_CreateTreatmentBookingRequest, T_DeliverTreatmentCycle, T_ForwardAccepted, T_ForwardAcceptedReferral, T_NewPatientConsultation, T_PrepareClinicLetter, T_RecordConsent, T_RecordDecision, T_RecordPatientConsent, T_RecordReferralDecision, T_RequestFollowUp
finance-team	6	T_Authorise, T_DetermineFunding, T_DetermineFundingRoute, T_RecordFundingApproval, T_RecordPayment, T_RequestFundingApproval
hospital-management	1	T_ReviewManagementReports
medical-secretaries	6	T_AdministrativeCheck, T_CheckDocumentation, T_CheckReferralDocuments, T_ReceiveReferral, T_Register, T_RegisterReferral
outpatient-bookings-team	9	T_ArrangeFollowUp, T_BookAppointment, T_ConfirmAppointment, T_ConfirmBooking, T_ConfirmFollowUp, T_ExpediteUrgentBooking, T_ReceiveBookingRequest, T_SelectAndBookSlot, T_SelectBookAppointment
patient-pathway-coordinators	0	
treatment-bookings-team	4	T_ConfirmTreatmentSchedule, T_DeliverTreatment, T_ValidateRequest, T_ValidateTreatmentRequest

4 What would falsify this

- A user with no group returning any task at all (the norole probe).
- The same task definition appearing in two role inboxes without the model declaring both candidate groups (one definition does declare two: T_Authorise, consultant-team and finance-team).
- A task definition declared in a model that no inbox returns: on 15 October, 52 of 84 declared definitions were routed; the remainder belong to processes that had not been driven at that point.
- The membership check: every demo user must be a member of exactly the group its candidate group names.

Reproduce: python 09_Tests_and_Tools/setup-rbac.py, then python 09_Tests_and_Tools/verify-rbac.py. The second script rewrites task-visibility.json and exits non-zero if any of the checks above fails.